

Monitoramento Entra ID — Detecção de Ameaças Baseadas em Identidade

Olá, meu nome é Cauã. Esta documentação apresenta os resultados dos meus estudos e a execução de uma atividade prática na plataforma TryHackMe, focada especificamente no **Monitoramento do Entra ID**.

Introdução

Atualmente, os ataques baseados em identidade representam o principal caminho de acesso inicial em ambientes de nuvem. Segundo dados de telemetria da própria Microsoft, mais de 99,9% dos ataques de comprometimento de conta poderiam ser evitados com a implementação de controles básicos, como a Autenticação Multifator (MFA). No entanto, os invasores continuam obtendo sucesso devido à alta incidência de configurações incorretas e lacunas nas políticas de segurança.

Neste documento, você acompanhará a investigação das técnicas de ataque mais comuns que têm como alvo as identidades do Entra ID. Ao longo da leitura, você verá:

- O funcionamento detalhado das técnicas comuns de ataque contra identidades no Entra ID;
- Como os recursos de segurança nativos do Entra ID ajudam a prevenir e detectar essas ameaças;
- A aplicação prática da caça a ameaças (*Threat Hunting*), utilizando logs de login e de auditoria para detectar cada uma dessas técnicas.

Ataques de Acesso Inicial: Pulverização de Senhas e Força Bruta

O Entra ID é um alvo frequente de ataques baseados em identidade devido à sua exposição pública. Esta etapa foca na detecção de duas técnicas principais através da análise de logs:

- **Pulverização de Senhas (Password Spraying):** O invasor testa um conjunto pequeno de senhas contra muitas contas diferentes para evitar o acionamento das políticas de bloqueio (*lockout*).
- **Força Bruta com Estrangulamento (Throttled Brute Force):** O invasor testa muitas senhas contra uma *única* conta, mas de forma espaçada no tempo para burlar os limites de bloqueio.

Investigação Prática no Splunk

Passo 1: Identificar a Origem dos Ataques Para encontrar falhas de login reais (ignorando erros intermediários) e mapear o comportamento dos atacantes, agrupei as falhas por IP e pela quantidade de contas alvo:

Splunk SPL

```
index="task-2" sourcetype="azure:aad:signin" "status.errorCode"!=0
conditionalAccessStatus!=success
| stats dc(userPrincipalName) as targeted_accounts, count as failures by ipAddress
| sort - failures
```

<pre> 1 index="task-2" sourcetype="azure:aad:signin" "status.errorCode"!=0 conditionalAccessStatus!=success 2 stats dc(userPrincipalName) as targeted_accounts, count as failures by ipAddress 3 sort - failures </pre>			All time
✓ 22 events (before 10/5/26 6:39:21.000 PM) No Event Sampling ▾			Job ▾ ▢ ↻ ⚙ ⬇ ⚡ Smart Mode ▾
Events Patterns Statistics (4) Visualization			
Show: 20 Per Page ▾ ✓ Format ▾ Preview: On			
ipAddress ▾		targeted_accounts ▾	failures ▾
94.20.222.248		7	14
38.165.231.218		1	4
149.102.234.27		1	2
2804:2488:7082:a4c0:901:9e5d:4cd7:ff0e		1	2

- **Pergunta:** Qual endereço IP está realizando uma pulverização de senha?
 - **Resposta:** 94[.]20[.]222[.]248
 - **Explicação:** Identificado na pesquisa pelo alto número de contas distintas atacadas a partir da mesma origem.
- **Pergunta:** Qual endereço IP está realizando uma força bruta de estrangulamento?
 - **Resposta:** 38[.]165[.]231[.]218
 - **Explicação:** Identificado pelo volume massivo de falhas concentrado contra apenas uma conta.

Passo 2: Identificar a Conta Comprometida Para confirmar se houve vazamento, filtrei apenas os acessos com sucesso (`status.errorCode=0`) originados dos IPs maliciosos mapeados:

Splunk SPL

```

index="task-2" sourcetype="azure:aad:signin" "status.errorCode"=0
| where ipAddress="<SUSPICIOUS_IP>"
| stats count by userPrincipalName, status.errorCode
| sort status.errorCode

```

- **Pergunta:** Qual é o endereço de e-mail do usuário que foi comprometido?
 - **Resposta:** amanda.costa@finegalo.thm

- **Explicação:** Revelado ao cruzar o IP atacante com os logs de autenticação bem-sucedida.

```
1 index="task-2" sourcetype="azure:aad:signin" "status.errorCode"=0
2 | where ipAddress="38.165.231.218"
3 | stats count by userPrincipalName, status.errorCode
4 | sort status.errorCode
```

✓ 3 events (before 10/5/26 6:44:01.000 PM) No Event Sampling ▾

Events Patterns **Statistics (1)** Visualization

Show: 20 Per Page ▾ Format ▾ ☒ Preview: On

userPrincipalName ⇅

amanda.costa@finegalo.thm

O que foi realizado

- **O que foi feito:** Investigação de ataques de acesso inicial no Entra ID utilizando o Splunk para filtrar e correlacionar logs de login.
- **Conceitos aprendidos:** A diferença entre Pulverização de Senhas e Força Bruta, e como os invasores adaptam essas TTPs (como o *throttling*) para burlar políticas de limite de bloqueio.
- **Importância:** Logins comprometidos não geram alertas tradicionais de rede ou malware. Filtrar corretamente os logs do Entra ID (`status.errorCode` e `conditionalAccessStatus`) em um SIEM é fundamental para detectar acessos indevidos antes da exfiltração de dados.

Políticas de Acesso Condicional e Proteção de Identidade

Mesmo possuindo credenciais válidas, um invasor costuma esbarrar em dois controles nativos do Entra ID:

- **Políticas de Acesso Condicional (CAP):** Mecanismo de regras (*if/then*) que pode conceder acesso, exigir MFA ou bloquear a requisição. Invasores mapeiam lacunas no escopo dessas políticas (ex: contas de serviço legadas isentas de MFA).
- **Proteção de Identidade:** Motor de Machine Learning que alimenta o CAP com pontuações de risco. Divide-se em **Risco de Login** (avaliação na hora do acesso, ex: IPs anônimos) e **Risco de Usuário** (histórico cumulativo da conta, ex: credenciais vazadas).

Investigação Prática no Splunk

Passo 1: Identificar a Conta e a Detecção de Risco Utilizei os logs de risco (`sourcetype="azure:aad:identity_protection:risky_user"` e `riskdetection`) para localizar contas alertadas pela Microsoft.

- **Pergunta:** Qual é o endereço de e-mail do usuário que está em risco no locatário?
 - **Resposta:** allan.senna@finegalo.thm
 - **Explicação:** Identificado diretamente nos alertas de usuários classificados como de risco.
- **Pergunta:** Quando foi a última tentativa arriscada de login e qual o tipo de risco identificado?
 - **Resposta:** 2026-03-03 13:51 | anonymizedIPAddress
 - **Aplicação:** Extraído ordenando o log de detecção de risco pela data mais recente e checando o campo **riskEventType** (que revela a tática do atacante, como uso de proxy anônimo).

Passo 2: Avaliar a Resposta da Política (CAP) Consultei os logs de login (**azure:aad:signin**) filtrando bloqueios (**conditionalAccessStatus=failure**) para validar a contenção do ataque.

Consulta Splunk:

```
index="task-3" sourcetype="azure:aad:signin"
conditionalAccessStatus=failure

| spath output=policies path=appliedConditionalAccessPolicies{}

| mvexpand policies

| spath input=policies output=policy_result path=result

| spath input=policies output=policy_name path=displayName

| where policy_result="failure"

| stats values(policy_name) as FailedPolicies by _time, appDisplayName,
userDisplayName, ipAddress, conditionalAccessStatus

| eval FailedPolicies=mvjoin(FailedPolicies, ", ")

| table _time, appDisplayName, userDisplayName, ipAddress,
conditionalAccessStatus, FailedPolicies

| sort - _time
```

- **Pergunta:** Qual é o nome da política (CAP) aplicada e qual endereço IP foi impedido de fazer login?
- **Resposta:** Block Suspicious Countries | 94[.]20[.]222[.]251
- **Explicação:** A consulta agrupa os resultados, extraíndo a política que retornou **failure** (campo **FailedPolicies**) e vinculando-a diretamente ao **ipAddress** da requisição bloqueada.

The screenshot shows a Splunk search interface. At the top, a KQL query is entered in the search bar:

```
1 index="task-3" sourcetype="azure:aad:signin" conditionalAccessStatus=failure
2 | spath output=policies path=appliedConditionalAccessPolicies{}
3 | mvexpand policies
4 | spath input=policies output=policy_result path=result
5 | spath input=policies output=policy_name path=displayName
6 | where policy_result="failure"
7 | stats values(policy_name) as FailedPolicies by _time, appDisplayName, userDisplayName, ipAddress, conditionalAccessStatus
8 | eval FailedPolicies=mvjoin(FailedPolicies, ", ")
9 | table _time, appDisplayName, userDisplayName, ipAddress, conditionalAccessStatus, FailedPolicies
10 | sort - _time
```

Below the query, the search results are displayed in a table. The table has 6 columns: `_time`, `appDisplayName`, `userDisplayName`, `ipAddress`, `conditionalAccessStatus`, and `FailedPolicies`. The first three rows of data are highlighted with yellow boxes:

_time	appDisplayName	userDisplayName	ipAddress	conditionalAccessStatus	FailedPolicies
2026-03-03 13:31:16	OfficeHome	Allan Senna	94.20.222.251	failure	Block Suspicious Countries
2026-03-03 13:31:04	OfficeHome	Allan Senna	94.20.222.251	failure	Block Suspicious Countries
2026-03-03 13:30:54	OfficeHome	Allan Senna	94.20.222.251	failure	Block Suspicious Countries

O que foi realizado

- **O que foi feito:** Auditoria integrada das Políticas de Acesso Condicional (CAP) e da Proteção de Identidade no Entra ID utilizando o Splunk.
- **Conceitos aprendidos:** A diferença entre Risco de Login e Risco de Usuário, e como dissecar os resultados no formato JSON dos logs de acesso condicional.
- **Importância:** Atacantes buscam incessantemente contas fora do escopo do CAP. Para o SOC, correlacionar os logs de detecção de risco com falhas de login (SIEM) é indispensável para confirmar se os controles de acesso estão bloqueando ativamente as TTPs dos invasores.

Técnicas de Desvio de MFA (Bypass)

O MFA (Autenticação Multifator) bloqueia a esmagadora maioria dos ataques baseados em credenciais. No entanto, invasores desenvolveram técnicas avançadas para contorná-lo sem quebrar criptografias. Esta etapa analisa táticas de desvio sob a perspectiva de monitoramento.

- **Fadiga de MFA (MFA Fatigue / Bombing):** O invasor com a senha válida aciona repetidos prompts de aprovação no aplicativo Authenticator do usuário, tentando vencê-lo pelo cansaço (engenharia social).
- **Troca de SIM (SIM Swapping):** Clonagem ou portabilidade maliciosa da linha telefônica para interceptar códigos de MFA via SMS.
- **AiTM (Adversary-in-the-Middle):** Uso de um proxy malicioso para interceptar a autenticação. O invasor não "quebra" o MFA; ele rouba o *token de sessão* emitido após o usuário legítimo aprovar o acesso.

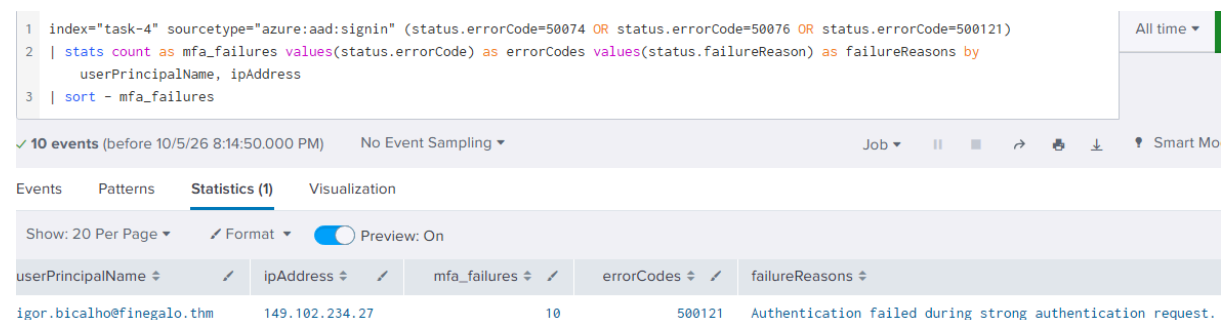
Investigação Prática no Splunk

Utilizando os logs de acesso ([task-4](#)), investiguei tentativas de desvio de MFA e o uso de credenciais e sessões roubadas através do rastreamento geográfico (Viagem Impossível).

Passo 1: Identificar o ataque de Fadiga de MFA Filtrei falhas específicas ligadas aos códigos de erro de desafio MFA (ex: 50074, 50076, 500121) para encontrar qual conta estava sendo bombardeada:

Splunk SPL

```
index="task-4" sourcetype="azure:aad:signin" (status.errorCode=50074 OR status.errorCode=50076 OR status.errorCode=500121)
| stats count as mfa_failures values(status.errorCode) as errorCodes values(status.failureReason) as failureReasons by userPrincipalName, ipAddress
| sort - mfa_failures
```



userPrincipalName	ipAddress	mfa_failures	errorCodes	failureReasons
igor.bicalho@finegalo.thm	149.102.234.27	10	500121	Authentication failed during strong authentication request.

- **Pergunta:** Qual usuário foi alvo de um ataque de fadiga de MFA?
- **Resposta:** igor.bicalho@finegalo.thm
- **Explicação:** Identificado na pesquisa pelo pico anômalo de tentativas fracassadas de MFA (**mfa_failures**) ligadas ao seu perfil.
- **Pergunta:** Qual é o código de erro dos prompts MFA com falha?
- **Resposta:** 500121
- **Explicação:** O campo **errorCodes** registrou falhas atreladas a recusas repetidas da aprovação do desafio pelo usuário legítimo.

Passo 2: Investigar o Acesso e a Viagem Impossível Como o atacante pode ter migrado de técnica (AiTM), busquei pelos logins bem-sucedidos (**status.errorCode=0**) para reconstruir a linha do tempo e cruzar as localizações geográficas.

Splunk SPL

```
index="task-4" sourcetype="azure:aad:signin" status.errorCode=0
| table _time, userPrincipalName, ipAddress, location.countryOrRegion, conditionalAccessStatus
| sort - _time
```

- **Pergunta:** Qual é o código do país no qual o usuário normalmente faz login antes do ataque?
- **Resposta:** DK
- **Explicação:** Identificado observando os registros históricos de acesso bem-sucedido (**status.errorCode=0**) imediatamente anteriores à data do incidente.
- **Pergunta:** Quando o invasor se autentica com sucesso na conta do usuário?

- **Resposta:** 2026-03-04 13:26
- **Explicação:** Rastreado localizando o primeiro evento com `errorCode=0` proveniente do IP atacante ou de uma localização impossível (ex: login bem-sucedido em um país diferente minutos após o último acesso no país de origem).

```
index="task-4" sourcetype="azure:aad:signin" status.errorCode=0
| table _time, userPrincipalName, ipAddress, location.countryOrRegion, conditionalAccessStatus
| sort - _time
```

_time	userPrincipalName	ipAddress	location.countryOrRegion	conditionalAccessStatus
2026-03-04 13:26:22	igor.bicalho@finegalo.thm	149.102.234.27	BR	success
2026-03-04 12:20:22	igor.bicalho@finegalo.thm	96.0.24.134	DK	success
2026-03-04 09:05:17	igor.bicalho@finegalo.thm	96.0.24.134	DK	success
2026-03-03 14:37:22	igor.bicalho@finegalo.thm	96.0.24.134	DK	success
2026-03-03 09:13:29	igor.bicalho@finegalo.thm	96.0.24.134	DK	success
2026-03-02 11:15:19	igor.bicalho@finegalo.thm	96.0.24.134	DK	success
2026-03-02 10:12:58	igor.bicalho@finegalo.thm	96.0.24.134	DK	success

O que foi realizado

- **O que foi feito:** Rastreamento de técnicas ativas de desvio de MFA, correlacionando fadiga de autenticação com eventos de viagem impossível utilizando os logs do Entra ID no Splunk.
- **Conceitos aprendidos:** A estrutura de avaliação MFA (Algo que você sabe + Algo que você tem). Identificação de ataques como MFA Fatigue através do agrupamento de códigos de erro (`50074`, `500121`) e o roubo de tokens de sessão (AiTM) através da análise de anomalias geográficas.
- **Importância:** Como AiTM foca em roubar a sessão já validada, a Proteção de Identidade (Acesso Condicional) vê o token como legítimo. Cabe à análise técnica baseada em logs (SIEM) conectar os pontos entre anomalias de localização e o comportamento histórico do usuário para identificar o comprometimento.

Escalada de Privilégios e Persistência

Após obter o acesso inicial, o invasor busca expandir seus privilégios e garantir sua permanência no ambiente, mesmo que a conta comprometida tenha a senha redefinida. Neste momento, a investigação muda dos logs de login para os **Logs de Auditoria**, que capturam alterações no estado do locatário (ex: criação de contas, delegação de funções e registro de dispositivos MFA).

Investigação Prática no Splunk

O foco da caça a ameaças em logs de auditoria (`azure:aad:audit`) baseia-se em responder a três perguntas: O que foi feito (`activityDisplayName`), quem fez (`initiatedBy`) e quem/o que foi afetado (`targetResources`).

Passo 1: Identificar a Criação de Contas Backdoor Invasores costumam criar novas contas fora do fluxo de RH/TI para manter o acesso caso o "Paciente Zero" seja descoberto. Filtrei o evento de criação de usuários:

Splunk SPL

```
index="task-5" sourcetype="azure:aad:audit" activityDisplayName="Add user"

| eval initiator=coalesce('initiatedBy.user.userPrincipalName','initiatedBy.app.displayName')

| eval userCreated='targetResources{}.userPrincipalName'

| table _time, activityDisplayName, initiator, userCreated
```

- **Pergunta:** Qual é o endereço de e-mail do usuário que o invasor criou?
- **Resposta:** raphael.maci@finegalo.thm
- **Explicação:** Identificado mapeando a conta comprometida como **initiator** (quem disparou a ação) e extraíndo o e-mail recém-criado na variável **userCreated**.

Passo 2: Investigar Atribuição de Funções (Privilege Escalation) Para validar se a conta recém-criada recebeu poderes administrativos, filtrei as delegações de funções:

Splunk SPL

```
index="task-5" sourcetype="azure:aad:audit" activityDisplayName="Add member to role"

| table _time, activityDisplayName, initiatedBy.user.userPrincipalName,
targetResources{}.userPrincipalName, targetResources{}.modifiedProperties{}.newValue

| sort - _time
```

activityDisplayName	initiatedBy.user.userPrincipalName	targetResources{}.userPrincipalName	targetResources{}.modifiedProperties{}.newValue
Add member to role	igor.bicalho@finegalo.thm	rafael.maci@finegalo.thm	"a9534b73-5228-4eb7-bed1-2b9e1dc914c9"
		null	"Global Administrator"
			"62e90394-69f5-4237-9190-012177145e10"
			"TenantAdmins"

- **Pergunta:** Qual função (**Role.DisplayName**) foi atribuída a esta nova conta?
- **Resposta:** Global Administrator
- **Explicação:** Extraído dos detalhes do campo **targetResources{}.modifiedProperties{}.newValue**, confirmando a elevação de privilégios.

Passo 3: Investigar Persistência via MFA Alternativo Se o atacante vincular seu próprio celular à conta da vítima, trocar a senha não adiantará. Busquei por novos cadastros de segurança de MFA:

Splunk SPL

```
index="task-5" sourcetype="azure:aad:audit" activityDisplayName="User started security info registration" loggedByService="Authentication Methods" operationType="Add"
```

```
| eval initiator=coalesce('initiatedBy.user.userPrincipalName','initiatedBy.app.displayName')
```

```
| table _time, activityDisplayName, initiator, initiatedBy.user.ipAddress,  
additionalDetails{}.value
```

- **Pergunta:** Quando o invasor adicionou um novo dispositivo MFA?
- **Resposta:** 2026-03-04 13:36
- **Explicação:** Rastreado via timestamp do evento de inclusão de dispositivo (métodos de autenticação), originado do IP do invasor.

O que foi realizado

- **O que foi feito:** Investigação de ações pós-comprometimento (TTPs de Escalada de Privilégios e Persistência) em um locatário Entra ID utilizando o Splunk.
- **Conceitos aprendidos:** A transição do monitoramento de logins (`azure:aad:signin`) para a auditoria de inquilinos (`azure:aad:audit`). Como extrair dados cruciais manipulando arrays JSON como `targetResources` e `initiatedBy`.
- **Importância:** Redefinir senhas é inútil se o invasor instalou um "backdoor" adicionando seu próprio dispositivo MFA ou criando contas de Administrador Ocultas. Auditar ativamente essas alterações é a única maneira de garantir a erradicação completa do invasor do ambiente.

Abuso de Aplicativo OAuth (Persistência)

O consentimento malicioso de aplicativos OAuth é um dos métodos de persistência mais furtivos do Entra ID. Como o acesso ocorre na camada de aplicação (via tokens de API), ele **sobrevive a redefinições de senha, bloqueios de conta e resets de MFA**. A única forma de interromper o acesso é revogando ativamente a concessão daquele aplicativo.

Análise de Permissões e Detecção no Splunk

Para avaliar a gravidade de um aplicativo malicioso, é crucial diferenciar os tipos de permissões concedidas:

- **Permissões Delegadas:** O aplicativo age em nome do usuário conectado, limitado exclusivamente ao que esse usuário pode acessar (ex: `Mail.Read`).
- **Permissões de Aplicação:** O aplicativo age por conta própria, possuindo acesso irrestrito em todo o locatário (*tenant-wide*). Exige consentimento de um Administrador (ex: `Mail.Read.All`, que permite ler **todas** as caixas de correio da organização).

Escopos de alto risco que exigem alerta imediato: Mail.ReadWrite.All, Files.ReadWrite.All, RoleManagement.ReadWrite.Directory e offline_access (que garante acesso contínuo através de tokens de atualização).

Deteção nos Logs de Auditoria Os eventos de consentimento são capturados nos logs de auditoria (`azure:aad:audit`) sob a ação "`Consent to application`". A consulta abaixo filtra quem autorizou o aplicativo e quais permissões foram concedidas, extraíndo os dados da matriz `targetResources`:

Splunk SPL

```
index="main" sourcetype="azure:aad:audit" activityDisplayName="Consent to application"
| eval initiator=coalesce('initiatedBy.user.userPrincipalName','initiatedBy.app.displayName')
| eval appName='targetResources{}.displayName'
| eval permissionsGranted='targetResources{}.modifiedProperties{}.newValue'
| table _time, initiator, appName, permissionsGranted
| sort - _time
```

O que foi realizado

- **O que foi feito:** Mapeamento do método de persistência avançada via abuso de aplicativos OAuth no Entra ID.
- **Conceitos aprendidos:** A diferença crítica entre Permissões Delegadas e Permissões de Aplicação, e a identificação de escopos de alto risco. Aprendi a rastrear concessões de consentimento (`Consent to application`) diretamente nos logs de auditoria do Azure.
- **Importância:** Incidentes envolvendo OAuth provam que redefinir senhas não encerra um ataque. Auditar os logs para rastrear e revogar permissões anômalas no registro de aplicativos é um passo técnico obrigatório para garantir a remediação completa do ambiente.

Conclusão

Este é o fim da documentação focada no Monitoramento do Entra ID.

Neste estudo prático, investiguei como detectar as principais ameaças baseadas em identidade (como Pulverização de Senhas e desvios de MFA), entendi como o Acesso Condicional e a Proteção de Identidade atuam em conjunto na defesa, e utilizei os logs de login e de auditoria para caçar técnicas avançadas de persistência pós-comprometimento, como a criação de contas backdoor e o abuso de aplicativos OAuth.

Obrigado por ler e acompanhar esta investigação!